Case Study: The Colonial Pipeline Ransomware Attack

The Crime Ransomware is a type of malware that encrypts a victim's files, rendering them inaccessible. The attackers then demand a payment—typically in cryptocurrency—in exchange for a decryption key. In the 2021 Colonial Pipeline incident, the "DarkSide" criminal group employed a "double extortion" tactic: they not only locked the data but also stole 100GB of sensitive information, threatening to leak it if the ransom was not paid.

How It Happens (Step-by-Step)

1. **Initial Access:** Attackers gain entry through a vulnerability. In this case, they used a single compromised password to access a legacy Virtual Private Network (VPN) account that lacked multi-factor authentication (MFA).
2. **Reconnaissance & Lateral Movement:** Once inside, the hackers moved through the corporate IT network to identify critical billing and accounting systems.
3. **Data Exfiltration:** Before encrypting, the attackers "scraped" and stole sensitive data to use as additional leverage.
4. **Encryption:** The ransomware was deployed, locking the company's administrative and billing systems.
5. **Extortion:** A digital ransom note appeared, demanding 75 Bitcoin (approx. $4.4 million) for the restoration of services.

The Target While ransomware can hit individuals, "Big Game Hunting" targets critical infrastructure, healthcare, and large corporations. Colonial Pipeline was targeted because its role in supplying 45% of the U.S. East Coast's fuel made the pressure to restore operations immense.

Consequences The company proactively shut down 5,500 miles of pipeline to prevent the malware from spreading to operational technology. This led to widespread fuel shortages, panic buying, and a state of emergency declaration. Although the ransom was paid, recovery took days, and the company faced millions in lost revenue, a $1 million civil penalty, and long-term reputational damage.

Source: U.S. Department of Energy & CISA (2021).